



# WEB APPLICATION PENETRATION TESTING REPORT

## DigiBank Web Application Assessment

|                    |                                            |
|--------------------|--------------------------------------------|
| Target Application | DigiBank Web Application                   |
| Target IP / Port   | 172.17.0.1 (Docker bridge) - Port 8080/TCP |
| Web Server         | Apache httpd 2.4.62 (Debian)               |
| Assessment Type    | Black-Box Web Application Penetration Test |
| Assessment Date    | March 13, 2026                             |
| Prepared By        | Sulav Adhikari                             |
| Organization       | Danphelink Pvt. Ltd.                       |
| Classification     | CONFIDENTIAL                               |

**Overall Risk Rating: CRITICAL**

## **Table of Contents**

|                                                            |            |
|------------------------------------------------------------|------------|
| <b>Table of Contents</b>                                   | <b>i</b>   |
| <b>Table of Figures</b>                                    | <b>ii</b>  |
| <b>Confidentiality Statement</b>                           | <b>iii</b> |
| <b>1. Target Information</b>                               | <b>1</b>   |
| <b>2. Port Scanning</b>                                    | <b>3</b>   |
| <b>3. Service Enumeration</b>                              | <b>4</b>   |
| 3.1 Directory / Content Enumeration (Gobuster)             | 4          |
| 3.2 SMB / Kerberos Enumeration                             | 6          |
| <b>4. Credential Attacks</b>                               | <b>7</b>   |
| <b>5. Initial Access</b>                                   | <b>8</b>   |
| <b>6. Remote Access</b>                                    | <b>10</b>  |
| <b>7. Vulnerabilities Identified</b>                       | <b>11</b>  |
| 7.1 OTP Authentication Bypass [CRITICAL]                   | 11         |
| 7.2 Negative Withdrawal Amount - Daily Limit Bypass [HIGH] | 16         |
| 7.3 Negative Money Transfer Manipulation [HIGH]            | 19         |
| 7.4 Negative Electricity Bill Payment [MEDIUM]             | 21         |
| <b>8. Vulnerability Summary</b>                            | <b>23</b>  |
| <b>9. Proof of Compromise</b>                              | <b>24</b>  |
| <b>10. Impact Assessment</b>                               | <b>25</b>  |
| <b>11. Remediation Recommendations</b>                     | <b>26</b>  |
| <b>12. Conclusion</b>                                      | <b>27</b>  |

## Table of Figures

| Figure              | Description                                                                            |
|---------------------|----------------------------------------------------------------------------------------|
| <b>Figure 1.1</b>   | Docker container setup - bankinglab running arya057/banking-app on port 8080           |
| <b>Figure 1.2</b>   | ip a output - docker0 interface at 172.17.0.1/16 confirmed                             |
| <b>Figure 1.3</b>   | Nmap scan - port 8080 open, Apache httpd 2.4.62, HTTP open-proxy detected              |
| <b>Figure 3.1</b>   | Gobuster enumeration results - page 1 (admin_login.php, /config, captcha.php)          |
| <b>Figure 3.2</b>   | Gobuster enumeration results - page 2 (full path listing)                              |
| <b>Figure 5.1</b>   | DigiBank homepage at http://172.17.0.1:8080                                            |
| <b>Figure 5.2</b>   | Burp Suite - Registration POST to /register.php (username=sulav, pin=3050)             |
| <b>Figure 5.3</b>   | Burp Suite - Registration 302 redirect to login.php                                    |
| <b>Figure 7.1.1</b> | DigiBank login page at /login.php (empty fields)                                       |
| <b>Figure 7.1.2</b> | Login page with credentials entered (username: sulav11)                                |
| <b>Figure 7.1.3</b> | Verify OTP page at /verify_otp.php                                                     |
| <b>Figure 7.1.4</b> | Invalid OTP error popup - OTP 120363 rejected by server                                |
| <b>Figure 7.1.5</b> | Burp Suite - Intercepted POST with verify_otp=1 and otp=120363 (validation active)     |
| <b>Figure 7.1.6</b> | Burp Suite - Modified POST with verify_otp removed - HTTP 302 to dashboard.php         |
| <b>Figure 7.1.7</b> | Dashboard after OTP bypass - Sulava Adhikari, balance Rs.100.00                        |
| <b>Figure 7.2.1</b> | Withdraw Money form showing Withdrawal Guidelines (Max Rs.10,000/day)                  |
| <b>Figure 7.2.2</b> | Burp Suite - POST /withdraw.php with amount=-10000 - successful response               |
| <b>Figure 7.2.3</b> | Withdrawal successful banner confirmed on /withdraw.php page                           |
| <b>Figure 7.2.4</b> | Dashboard after two withdrawals - Balance Rs.20,100.00                                 |
| <b>Figure 7.2.5</b> | Dashboard after three withdrawals - Balance Rs.30,100.00                               |
| <b>Figure 7.3.1</b> | Burp Suite - POST /transfer.php with amount=-32000 - Transfer successful               |
| <b>Figure 7.3.2</b> | Dashboard after negative transfers - Savings Rs.94,100.00                              |
| <b>Figure 7.3.3</b> | Transfer form dropdown showing Fixed Deposit balance Rs.-64,000.00                     |
| <b>Figure 7.4.1</b> | Burp Suite - POST /electricity.php with amount=-15000 - Electricity payment successful |
| <b>Figure 7.4.2</b> | Final dashboard - Total Balance Rs.60,100.00; Savings Rs.124,100.00                    |

## Confidentiality Statement

---

This report has been prepared exclusively for Danphelink Pvt. Ltd. as part of the Penetration Testing Training Programme. The information contained herein is strictly confidential and intended solely for the authorized recipient. This document must not be reproduced, distributed, or disclosed to any third party without prior written consent.

All findings relate to the DigiBank web application hosted at 172.17.0.1:8080 (Docker container bankinglab mapped from 127.0.0.1:8080) and tested on March 13, 2026. Testing was conducted within an authorized, isolated laboratory environment. No real financial data, live production systems, or real user accounts were accessed or affected during this assessment.

|                        |                                           |
|------------------------|-------------------------------------------|
| <b>Prepared By</b>     | Sulav Adhikari                            |
| <b>Organization</b>    | Danphelink Pvt. Ltd.                      |
| <b>Programme</b>       | Penetration Testing Training Programme    |
| <b>Assessment Date</b> | March 13, 2026                            |
| <b>Report Date</b>     | March 13, 2026                            |
| <b>Classification</b>  | CONFIDENTIAL - Authorized Recipients Only |

## 1. Target Information

The table below summarises key system details gathered during the initial reconnaissance phase. The DigiBank application runs inside a Docker container (image: arya057/banking-app, name: bankinglab) on the Kali Linux assessment host, launched with the command shown in Figure 1.1. The container maps port 80 internally to host port 8080, accessible via the Docker bridge IP 172.17.0.1 and the loopback address 127.0.0.1.

|                               |                                                                           |
|-------------------------------|---------------------------------------------------------------------------|
| <b>Target IP Address</b>      | 172.17.0.1 (Docker bridge) / 127.0.0.1 (loopback)                         |
| <b>Target Port</b>            | 8080 / TCP                                                                |
| <b>Application Name</b>       | DigiBank - Revolutionary Banking Experience                               |
| <b>Web Server</b>             | Apache httpd 2.4.62 (Debian)                                              |
| <b>Server Header</b>          | Apache/2.4.62 (Debian) - version explicitly disclosed in response headers |
| <b>Docker Bridge IP</b>       | 172.17.0.1/16 (docker0 interface confirmed via ip a)                      |
| <b>eth0 IP</b>                | 192.168.150.129/24 (assessment host LAN interface)                        |
| <b>Transport Security</b>     | HTTP only (plaintext) - no TLS/HTTPS on any endpoint                      |
| <b>Container Name</b>         | bankinglab (arya057/banking-app image)                                    |
| <b>Container Port Mapping</b> | 0.0.0.0:8080 to 80/tcp, [::]:8080 to 80/tcp                               |

```
(kali@kali)~$ sudo docker run -d -p 8080:80 --name bankinglab arya057/banking-app
308d3d2f3097fb319aa462e617e00a6df2908646609ba1ff972d24125d32a743

(kali@kali)~$ sudo docker ps -a
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS                               NAMES
308d3d2f3097   arya057/banking-app  "/entrypoint.sh"        3 seconds ago  Up 2 seconds  0.0.0.0:8080->80/tcp, [::]:8080->80/tcp  bankinglab
```

Figure 1.1: docker run and docker ps -a confirming bankinglab container UP on port 8080

```
(kali@kali)-[~/sulavbankingapp]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 00:0c:29:cd:5c:9c brd ff:ff:ff:ff:ff:ff
    inet 192.168.150.129/24 brd 192.168.150.255 scope global dynamic noprefixroute eth0
        valid_lft 1247sec preferred_lft 1247sec
    inet6 fe80::20c:29ff:fe5c:9c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:60:a6:2f:a4 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:60ff:fea6:2fa4/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
5: vethfd09b3a@if4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master docker0 state UP group default
    link/ether 9e:6f:73:bf:20:85 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet6 fe80::9c6f:73ff:febf:2085/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever

(kali@kali)-[~/sulavbankingapp]
$
```

Figure 1.2: ip a output - docker0 inet 172.17.0.1/16 confirmed

```
(kali@kali)-[~/sulavbankingapp]
$ nmap -sC -sV -p 8080 127.0.0.1
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-13 13:56 +0530
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000073s latency).

PORT      STATE SERVICE VERSION
8080/tcp  open  http    Apache httpd 2.4.62 ((Debian))
|_http-title: DigiBank - Revolutionary Banking Experience
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: Apache/2.4.62 (Debian)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.95 seconds

(kali@kali)-[~/sulavbankingapp]
$
```

Figure 1.3: nmap -sC -sV -p 8080 127.0.0.1 - Apache httpd 2.4.62, port 8080 open, http-open-proxy flagged

## 2. Port Scanning

An Nmap service scan with default scripts (-sC) and version detection (-sV) was performed against the target on port 8080. The DigiBank application is hosted inside a Docker container accessible at 127.0.0.1:8080 (loopback) and 172.17.0.1:8080 (Docker bridge). The scan confirmed a single open port.

### Command Used:

```
nmap -sC -sV -p 8080 127.0.0.1
```

| Port     | State | Service | Version / Banner                                                                    |
|----------|-------|---------|-------------------------------------------------------------------------------------|
| 8080/tcp | Open  | HTTP    | Apache httpd 2.4.62 (Debian) - http-open-proxy: Proxy might be redirecting requests |

### Key Observations:

- The banking application is served exclusively over plain HTTP with no TLS encryption. All credentials, session cookies, OTP values, and transaction data transit in cleartext.
- The http-open-proxy NSE script flagged the server, indicating the HTTP CONNECT method may be active.
- The Server response header explicitly discloses Apache version 2.4.62 (Debian), providing precise version information for CVE lookups.
- The application title "DigiBank - Revolutionary Banking Experience" confirms the correct target application.

### 3. Service Enumeration

#### 3.1 Directory / Content Enumeration (Gobuster)

Gobuster was run in directory enumeration mode using the dirb/common.txt wordlist with extensions php, txt, conf, bak against the web root. The scan identified significant paths indicating a PHP-based backend with exposed configuration and model directories.

##### Command Used:

```
gobuster dir \ -u http://127.0.0.1:8080 \ -w /usr/share/wordlists/dirb/common.txt \ -x php,txt,conf,bak
```

| Path / File         | HTTP Status  | Risk   | Notes                                                                   |
|---------------------|--------------|--------|-------------------------------------------------------------------------|
| admin_login.php     | 200 OK       | HIGH   | Admin login panel directly accessible without authentication            |
| captcha.php         | 200 OK       | MEDIUM | CAPTCHA handler exposed - potential for bypass or logic abuse           |
| /config/            | 301 Redirect | HIGH   | Configuration directory - may expose database credentials or API keys   |
| /models/            | 301 Redirect | MEDIUM | Application data models directory - PHP logic files potentially exposed |
| /includes/          | 301 Redirect | MEDIUM | Server-side includes directory - PHP logic files potentially accessible |
| /uploads/           | 301 Redirect | HIGH   | File upload directory publicly accessible                               |
| change_password.php | 200 OK       | MEDIUM | Password change page accessible unauthenticated - potential CSRF flaw   |
| forgot_password.php | 200 OK       | LOW    | Password reset page - potential account enumeration via error messages  |
| register.php        | 200 OK       | INFO   | Registration page publicly accessible (expected)                        |
| login.php           | 200 OK       | INFO   | Login page confirmed accessible                                         |
| settings.php        | 200 OK       | MEDIUM | Settings page present - access controls to verify                       |
| transfer.php        | 302 Redirect | INFO   | Transfer page redirects unauthenticated users to login (expected)       |



```
kali@kali: ~/sulavbankingapp kali@kali: ~/sulavbankingapp
(kali@kali)~$ gobuster dir \
-u http://127.0.0.1:8080 \
-w /usr/share/wordlists/dirb/common.txt \
-x php,txt,conf,bak

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://127.0.0.1:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,conf,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 276]
.hta.php (Status: 403) [Size: 276]
.hta (Status: 403) [Size: 276]
.hta.conf (Status: 403) [Size: 276]
.htaccess.php (Status: 403) [Size: 276]
.htaccess.conf (Status: 403) [Size: 276]
.hta.bak (Status: 403) [Size: 276]
.htpasswd.conf (Status: 403) [Size: 276]
.htaccess.bak (Status: 403) [Size: 276]
.htpasswd.bak (Status: 403) [Size: 276]
.htpasswd.txt (Status: 403) [Size: 276]
.htaccess.txt (Status: 403) [Size: 276]
.hta.txt (Status: 403) [Size: 276]
.htpasswd.php (Status: 403) [Size: 276]
.htpasswd (Status: 403) [Size: 276]
admin.php (Status: 302) [Size: 0] [→ login.php]
admin_login.php (Status: 200) [Size: 1913]
admin.php (Status: 302) [Size: 0] [→ login.php]
accounts.php (Status: 302) [Size: 0] [→ login.php]
captcha.php (Status: 200) [Size: 4457]
cards.php (Status: 302) [Size: 0] [→ login.php]
```

Figure 3.1: Gobuster v3.8.2 - enumeration page 1 showing admin\_login.php (200), /config (301)

```
kali@kali: ~/sulavbankingapp kali@kali: ~/sulavbankingapp

.htpasswd.txt (Status: 403) [Size: 276]
.htaccess.txt (Status: 403) [Size: 276]
.hta.txt (Status: 403) [Size: 276]
.htpasswd.php (Status: 403) [Size: 276]
.htpasswd (Status: 403) [Size: 276]
admin.php (Status: 302) [Size: 0] [→ login.php]
admin_login.php (Status: 200) [Size: 1913]
admin.php (Status: 302) [Size: 0] [→ login.php]
accounts.php (Status: 302) [Size: 0] [→ login.php]
captcha.php (Status: 200) [Size: 4457]
cards.php (Status: 302) [Size: 0] [→ login.php]
change_password.php (Status: 200) [Size: 207]
config (Status: 301) [Size: 314] [→ http://127.0.0.1:8080/config/]
complaints.php (Status: 302) [Size: 0] [→ login.php]
dashboard.php (Status: 302) [Size: 0] [→ login.php]
flights.php (Status: 302) [Size: 0] [→ login.php]
forgot_password.php (Status: 200) [Size: 3043]
includes (Status: 301) [Size: 316] [→ http://127.0.0.1:8080/includes/]
index.php (Status: 200) [Size: 39998]
index.php (Status: 200) [Size: 39998]
internet.php (Status: 302) [Size: 0] [→ login.php]
login.php (Status: 200) [Size: 3103]
logout.php (Status: 302) [Size: 0] [→ login.php]
models (Status: 301) [Size: 314] [→ http://127.0.0.1:8080/models/]
mobile.php (Status: 302) [Size: 0] [→ login.php]
register.php (Status: 200) [Size: 17095]
server-status (Status: 403) [Size: 276]
settings.php (Status: 200) [Size: 201]
static (Status: 301) [Size: 314] [→ http://127.0.0.1:8080/static/]
transfer.php (Status: 302) [Size: 0] [→ login.php]
uploads (Status: 301) [Size: 315] [→ http://127.0.0.1:8080/uploads/]
Progress: 23065 / 23065 (100.00%)

Finished

(kali@kali)~$
```

Figure 3.2: Gobuster - full results including /includes, /models, /uploads, forgot\_password.php, register.php

### 3.2 SMB / Kerberos Enumeration

Not applicable. The assessment was scoped exclusively to the web application on port 8080. No SMB, Kerberos, LDAP, or other network services were identified. Tools such as enum4linux, Kerbrute, and CrackMapExec were not applicable in this web application context.

## 4. Credential Attacks

---

No traditional network-layer credential attacks were conducted. The target does not expose authentication services such as SMB or Kerberos on the assessed port. Credential-related vulnerabilities were identified at the application layer. The OTP Authentication Bypass (documented in Section 7.1) allows an attacker with valid credentials to skip two-factor authentication entirely. A test account was registered through the application own registration flow (username: sulav, transaction\_pin: 3050, initial\_deposit: Rs.100) - no external credential-gathering techniques were required.

## 5. Initial Access

Initial access to the DigiBank application was obtained by browsing to the target URL over HTTP. The application was fully accessible from the assessment host without any additional configuration.

`http://172.17.0.1:8080/` # Also accessible via loopback: `http://127.0.0.1:8080/`

A test account was registered with the following credentials using Burp Suite to capture the registration request:

|                        |                       |
|------------------------|-----------------------|
| <b>Username</b>        | sulav11               |
| <b>Email</b>           | sulavadh124@gmail.com |
| <b>Password</b>        | Mp40awm@#             |
| <b>Transaction PIN</b> | 3050                  |
| <b>Initial Deposit</b> | Rs.100.00             |

The application presents a two-step authentication flow: Step 1 requires username and password; Step 2 requires a 6-digit OTP sent to the registered email. The OTP bypass technique documented in Section 7.1 was used to skip Step 2 entirely, granting a fully authenticated session as Sulava Adhikari without ever receiving or submitting a valid OTP.

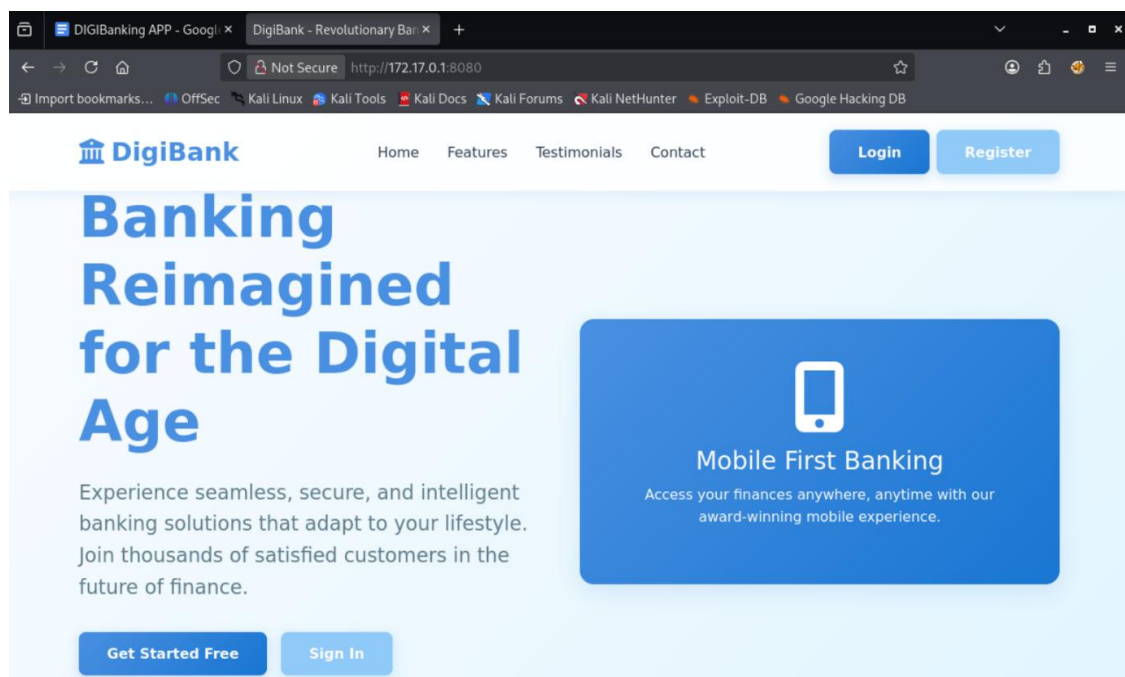


Figure 5.1: DigiBank homepage - "Banking Reimagined for the Digital Age" served over plain HTTP

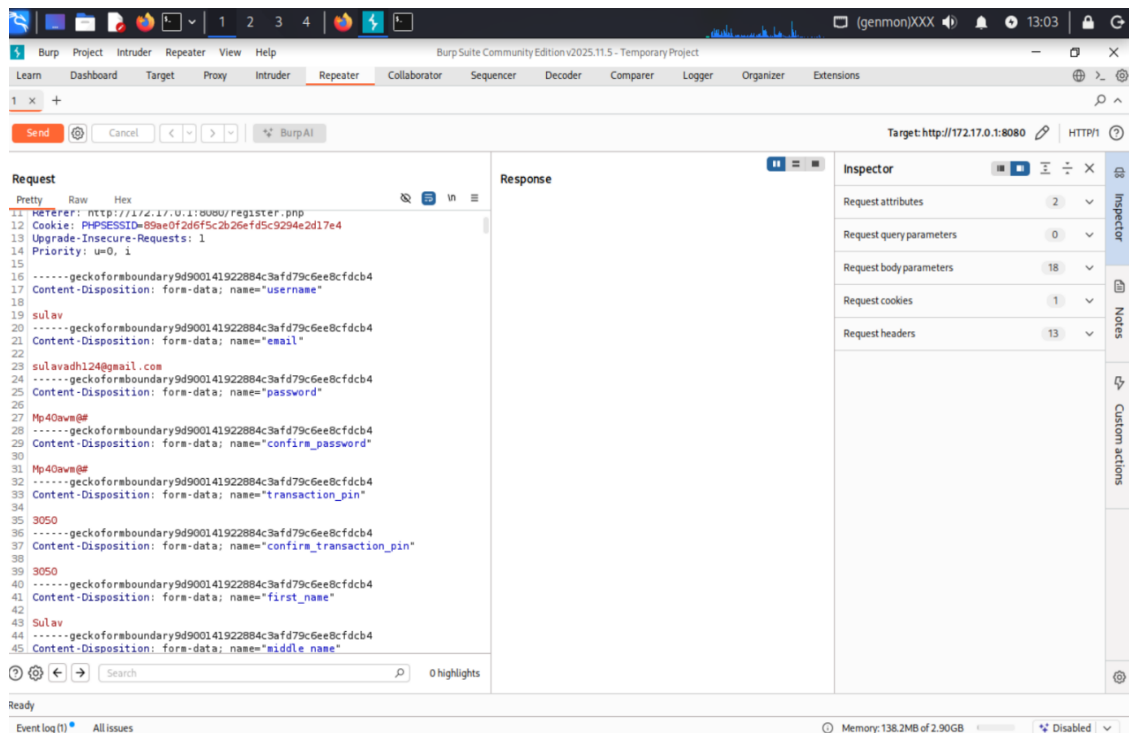


Figure 5.2: Burp Repeater - registration request showing username=sulav, transaction\_pin=3050, initial\_deposit=100

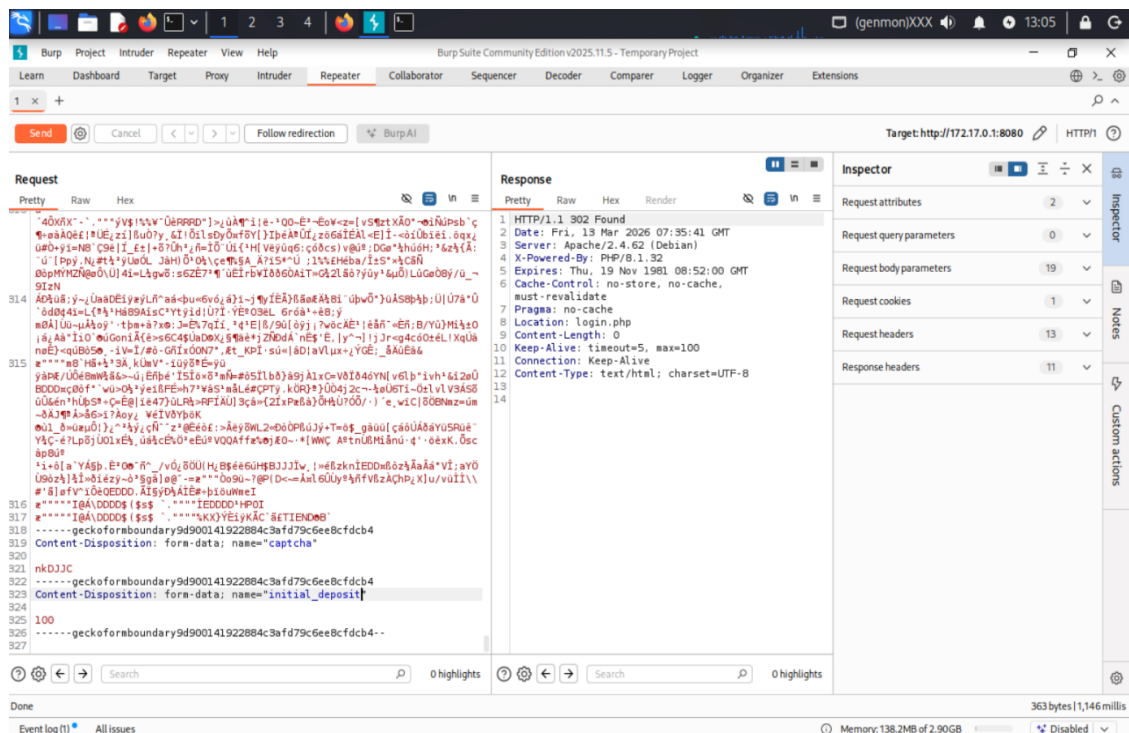


Figure 5.3: HTTP 302 Found response redirecting to login.php after successful account registration

## 6. Remote Access

---

Not applicable. The assessment did not progress to OS-level remote access. No shell sessions were obtained via tools such as Evil-WinRM, Metasploit, or netcat. All exploitation was performed entirely at the web application layer within the HTTP/PHP session context. OS-level privilege escalation was outside the scope of this black-box web application engagement.

## 7. Vulnerabilities Identified

Four distinct vulnerabilities were identified through manual black-box testing of the DigiBank web application. Each finding is documented with severity classification, affected endpoint, CVSS v3 estimate, proof-of-concept HTTP requests, reproduction steps, evidence screenshots, and business impact assessment.

1 CRITICAL

2 HIGH

1 MEDIUM

0 LOW

### 7.1 OTP Authentication Bypass [CRITICAL]

|                   |                                                                        |
|-------------------|------------------------------------------------------------------------|
| Severity          | Critical                                                               |
| Category          | Broken Authentication / Missing Server-Side Authentication Enforcement |
| Affected Endpoint | POST /verify_otp.php                                                   |
| CVSS v3 Estimate  | 9.8 - Critical (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)          |

#### Description:

The DigiBank login flow consists of two steps: (1) username and password verification, and (2) a 6-digit OTP sent to the registered email. The OTP verification endpoint at /verify\_otp.php checks for the presence of a verify\_otp parameter in the POST body to determine whether to validate the submitted OTP. When this parameter is omitted, the server bypasses OTP validation entirely and issues an authenticated session redirect to dashboard.php - regardless of whether the OTP is valid. The server's authentication state machine is controlled by a client-supplied parameter rather than server-enforced session state.

#### Step-by-Step Reproduction:

- Configure Burp Suite as an HTTP proxy and navigate to the DigiBank login page at <http://172.17.0.1:8080/login.php>.
- Enter valid account credentials (username: sulav11, password filled) and submit the login form.
- The application redirects to /verify\_otp.php and prompts for a 6-digit OTP.
- Enter any incorrect OTP (e.g., 120363) and observe the "Invalid OTP. Please try again." error confirming validation is active for normal requests.
- In Burp Suite Repeater, send POST /verify\_otp.php with verify\_otp=1&otp=120363 - server returns "Invalid OTP."
- Remove the verify\_otp=1 parameter entirely, leaving only otp=120363 in the POST body. Forward the modified request.
- The server responds with HTTP 302 Found and Location: dashboard.php. Authentication bypass is complete.

## Proof-of-Concept HTTP Requests:

Normal request - OTP validation active (error returned):

```
POST /verify_otp.php HTTP/1.1 Host: 172.17.0.1:8080 Content-Type: application/x-www-form-urlencoded Cookie: PHPSESSID=89ae0f2d6f5c2b26efd5c9294e2d17e4 verify_otp=1&otp=120363 >>> Response: "Invalid OTP. Please try again."
```

Modified request - verify\_otp removed (bypass succeeds):

```
POST /verify_otp.php HTTP/1.1 Host: 172.17.0.1:8080 Content-Type: application/x-www-form-urlencoded Cookie: PHPSESSID=89ae0f2d6f5c2b26efd5c9294e2d17e4 otp=120363 >>> HTTP/1.1 302 Found >>> Location: dashboard.php >>> [AUTHENTICATION BYPASS SUCCESSFUL - FULL SESSION GRANTED]
```

## Evidence Screenshots:

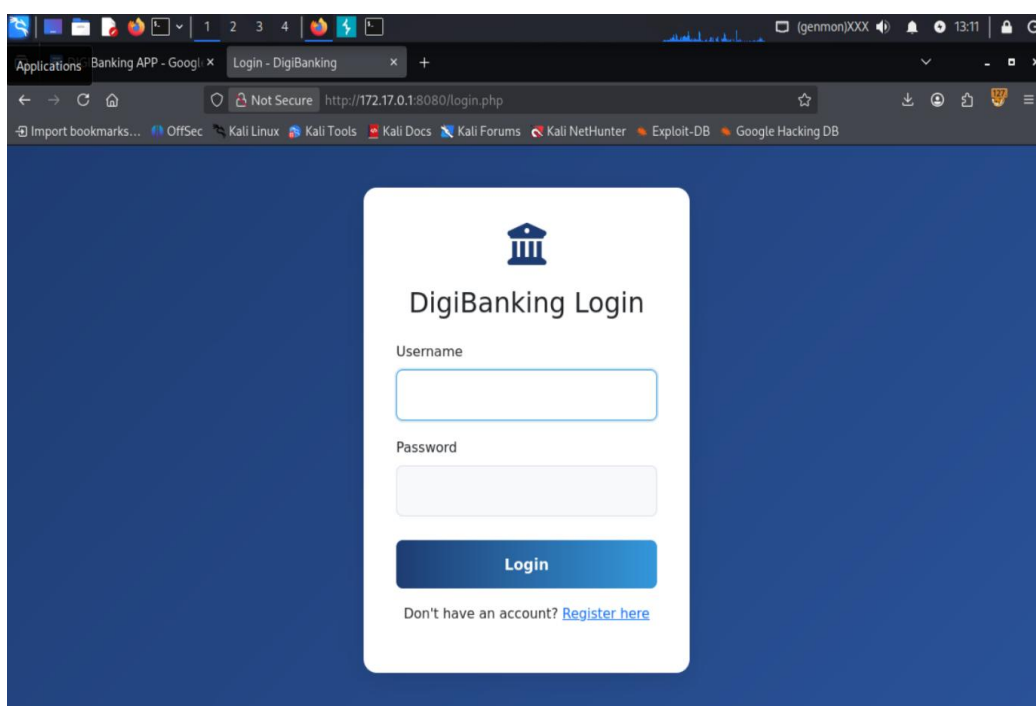


Figure 7.1.1: Login page at /login.php - username and password fields empty



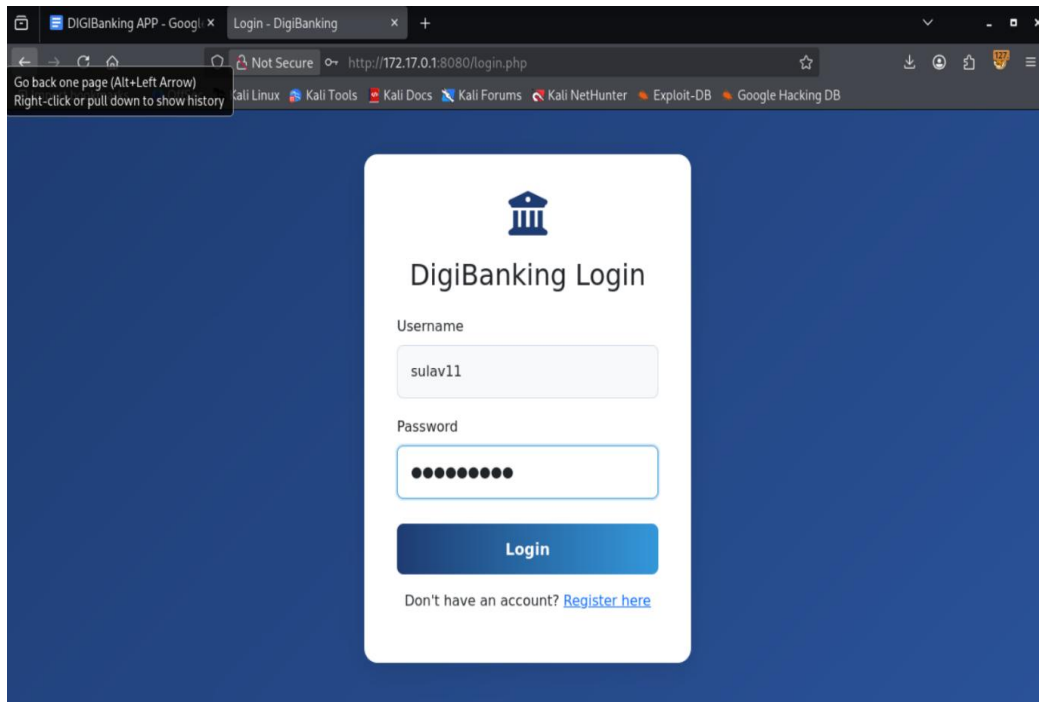


Figure 7.1.2: Login page with username=sulav11 and password entered

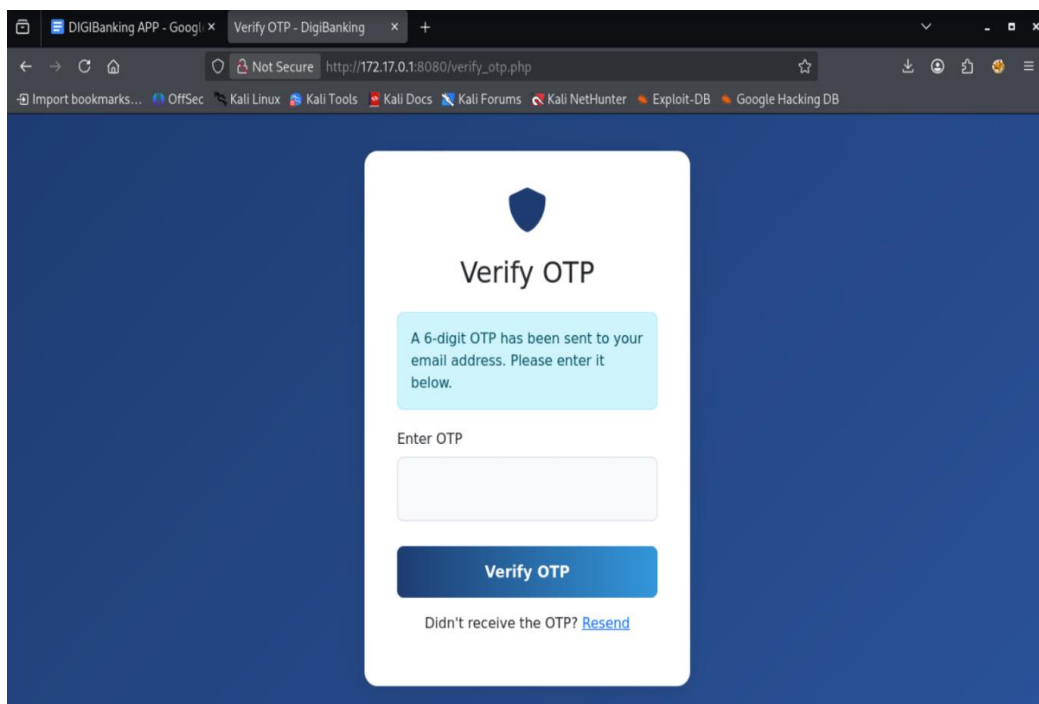


Figure 7.1.3: OTP verification page at /verify\_otp.php

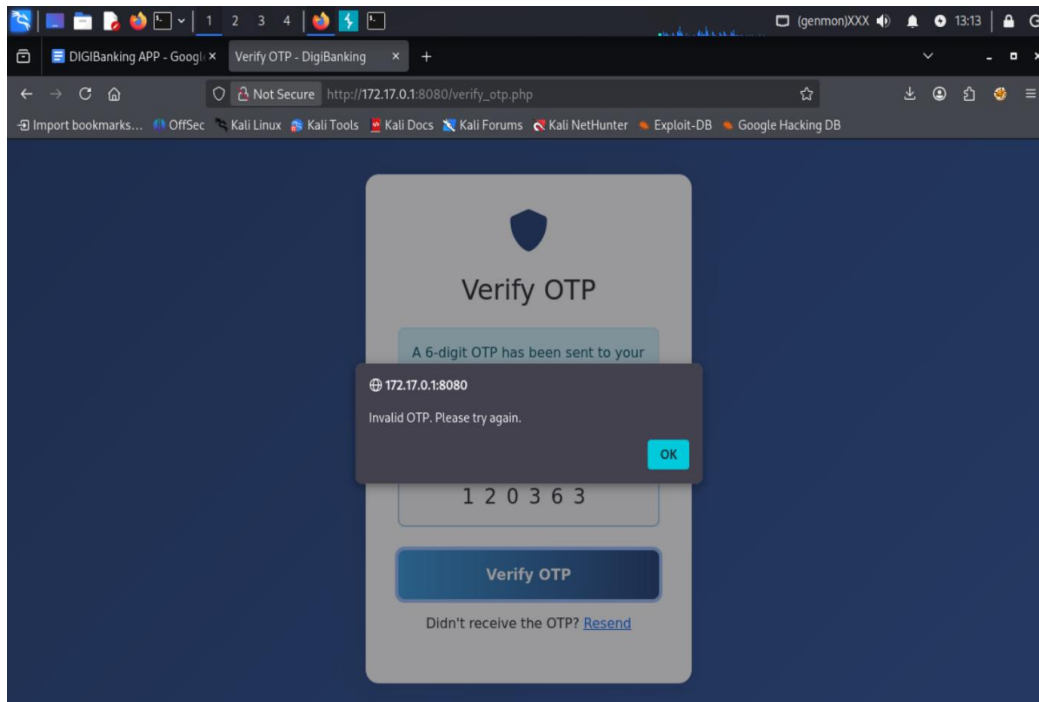


Figure 7.1.4: "Invalid OTP. Please try again." popup - OTP 120363 rejected

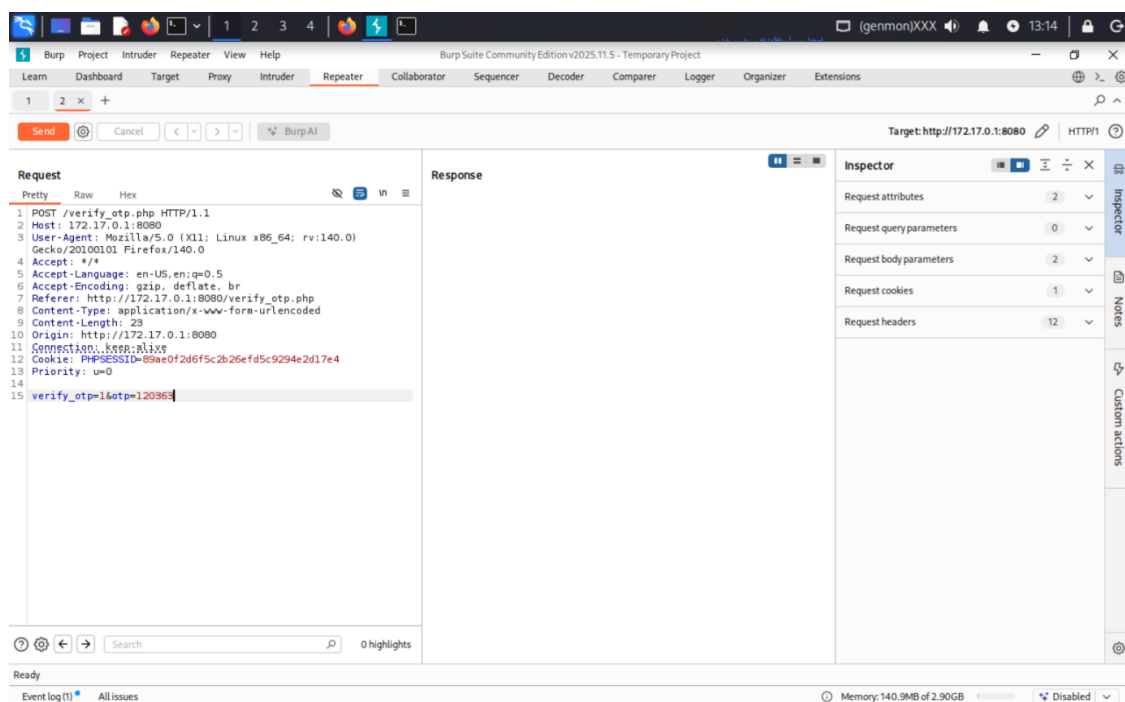


Figure 7.1.5: Burp Repeater - POST body: verify\_otp=1&otp=120363 (validation active, error returned)

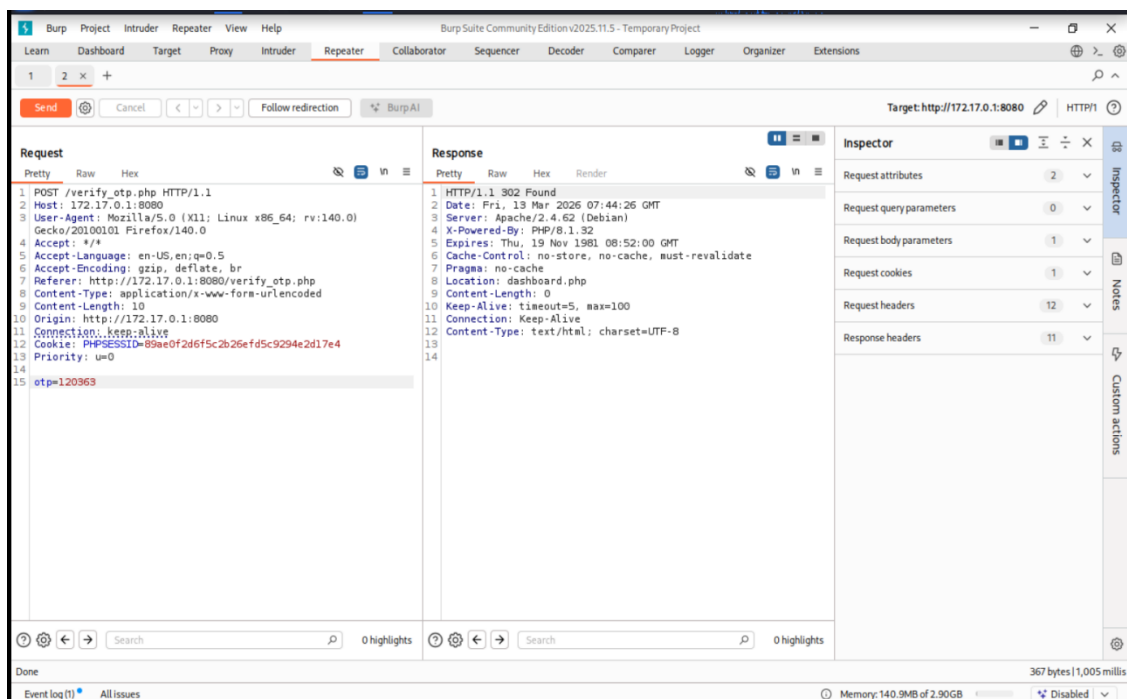


Figure 7.1.6: Modified POST body: otp=120363 only - server returns HTTP 302 to dashboard.php

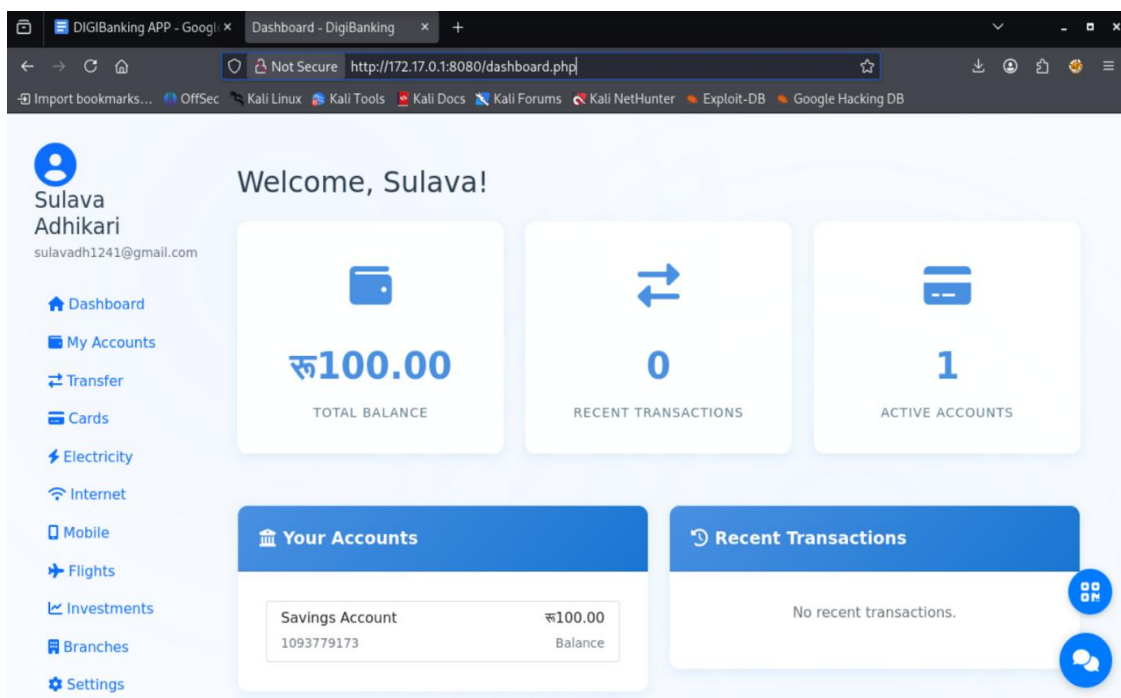


Figure 7.1.7: Dashboard loaded as Sulava Adhikari (sulavadh1241@gmail.com) - Savings 1093779173, Balance Rs.100.00

### Impact:

Any attacker with valid account credentials can immediately access any user account by removing a single POST parameter. The entire two-factor authentication layer is rendered completely ineffective. This vulnerability is rated Critical because it requires no special tools or privileged access and is trivially reproducible in under 60 seconds using any browser and HTTP proxy.

## 7.2 Negative Withdrawal Amount - Daily Limit Bypass [HIGH]

|                   |                                                                                    |
|-------------------|------------------------------------------------------------------------------------|
| Severity          | High                                                                               |
| Category          | Business Logic Vulnerability / Improper Input Validation - Two Independent Vectors |
| Affected Endpoint | POST /withdraw.php                                                                 |
| CVSS v3 Estimate  | 8.1 - High (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H)                          |

### Description:

Two independent bypass vectors were identified. Vector 1 - Negative Amount Bypass: The withdrawal endpoint does not validate that the submitted amount is positive. Submitting amount=-10000 causes the server to credit the account rather than debit it, bypassing both the daily limit and sign validation. The server returns "Withdrawal request successful!" and issues a token number. Vector 2 - Cumulative Daily Limit Not Enforced: The Rs.10,000/day limit is checked per-transaction rather than as an aggregate daily total. Multiple separate requests each succeed independently, making it possible to extract far more than the stated daily limit.

### Proof-of-Concept HTTP Request:

POST /withdraw.php HTTP/1.1 Host: 172.17.0.1:8080 Content-Type: application/x-www-form-urlencoded Cookie: PHPSESSID=89ae0f2d6f5c2b26efd5c9294e2d17e4 account\_id=100077cd-d5f8-476a-a2b5-35ca297af2c6&amount=-10000&transaction\_pin=3050&withdraw= >>> Result: "Withdrawal request successful! token number: 390" >>> Account credited +Rs.10,000 instead of debited

### Evidence Screenshots:

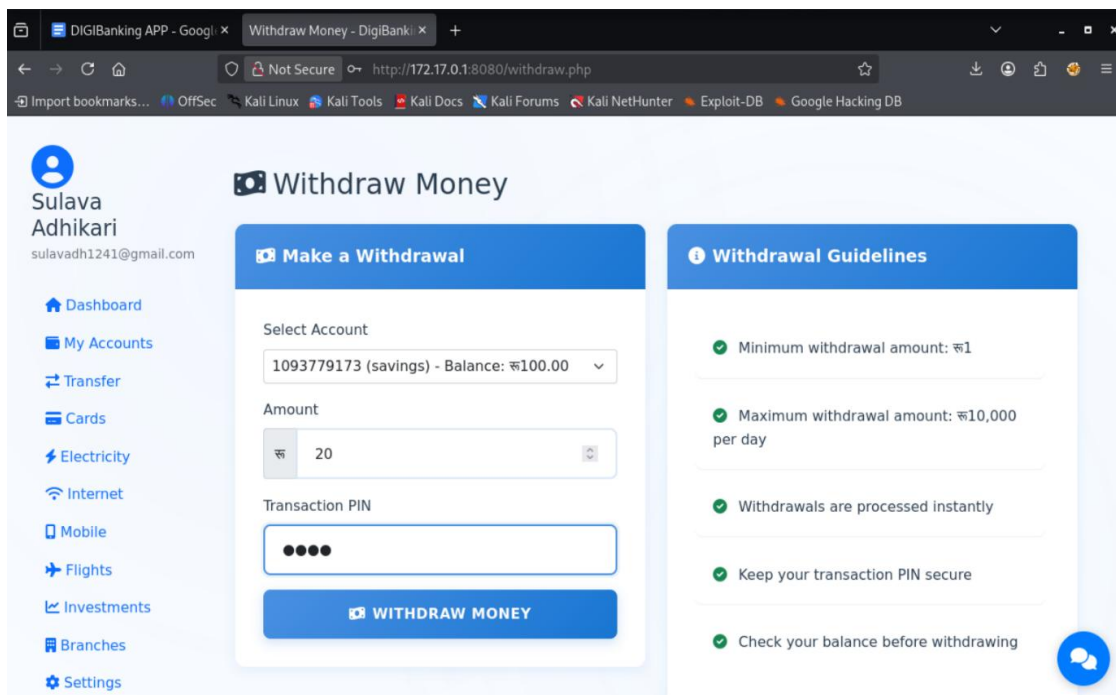


Figure 7.2.1: Withdraw form - account 100077cd... (Savings, Balance Rs.100.00); Max withdrawal Rs.10,000/day stated

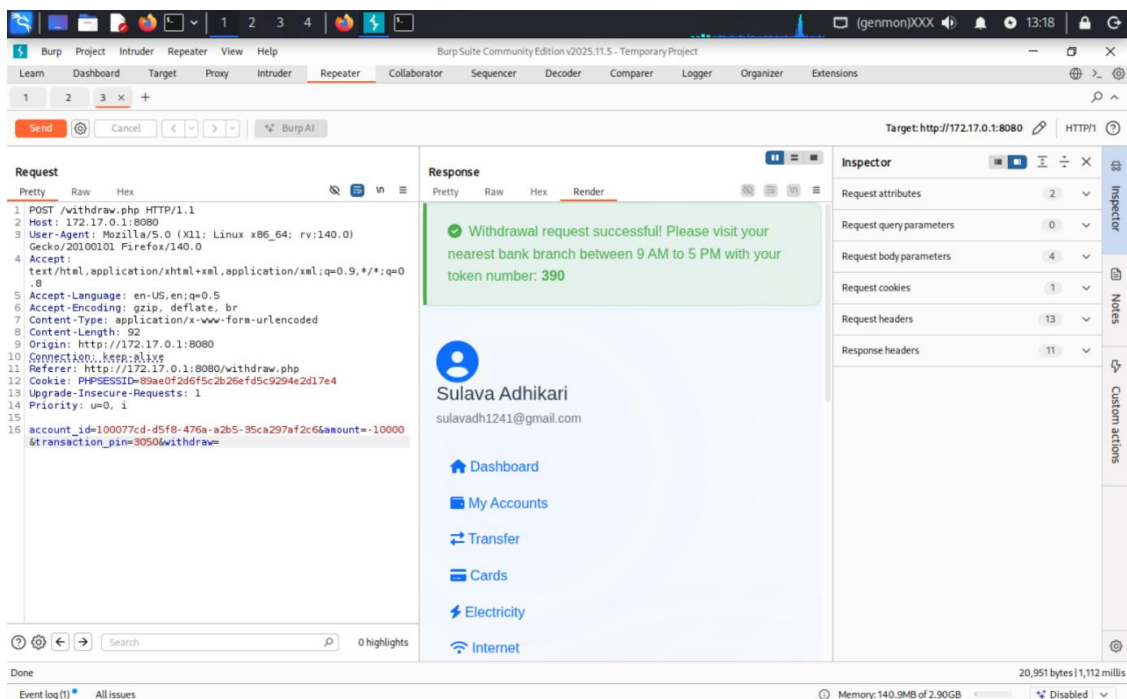


Figure 7.2.2: Burp Repeater - amount=-10000, transaction\_pin=3050; response: "Withdrawal request successful! token: 390"

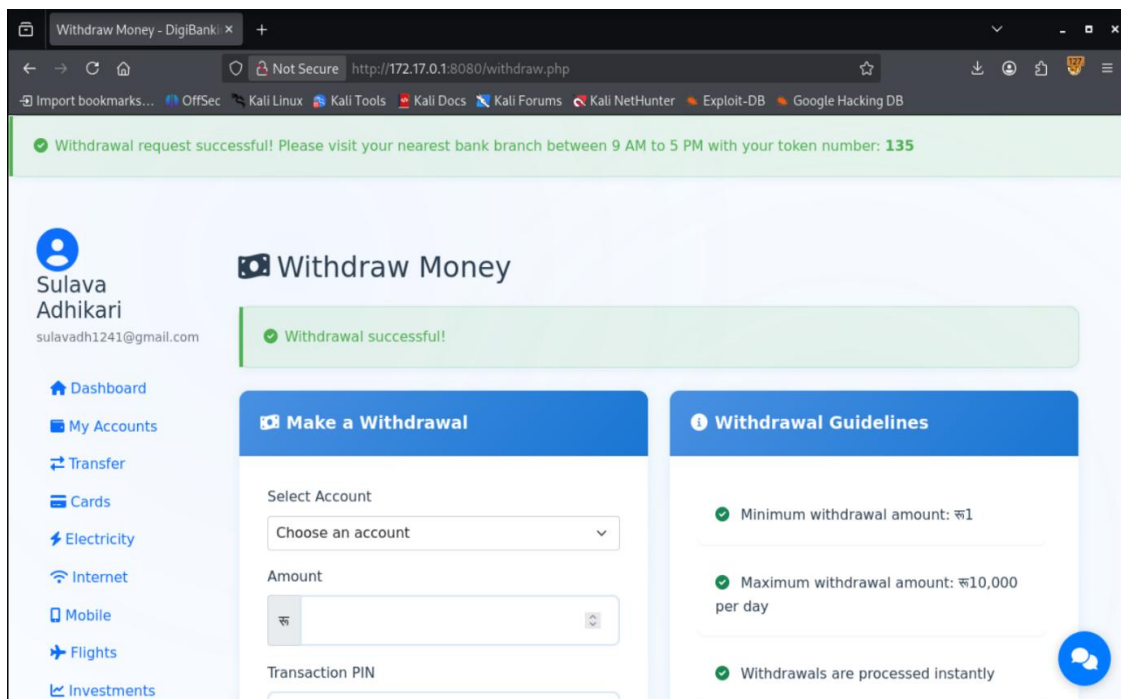


Figure 7.2.3: "Withdrawal successful!" banner confirmed on /withdraw.php page (token 135)

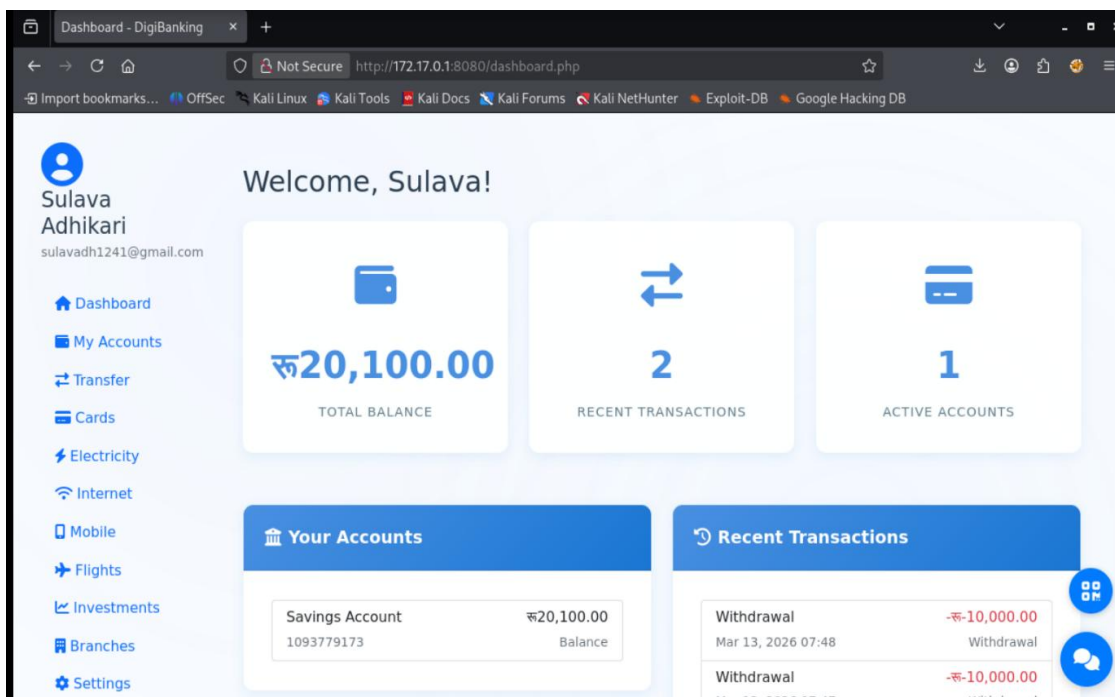


Figure 7.2.4: Dashboard - Total Balance Rs.20,100.00; Savings 1093779173 Rs.20,100.00; 2 withdrawal transactions

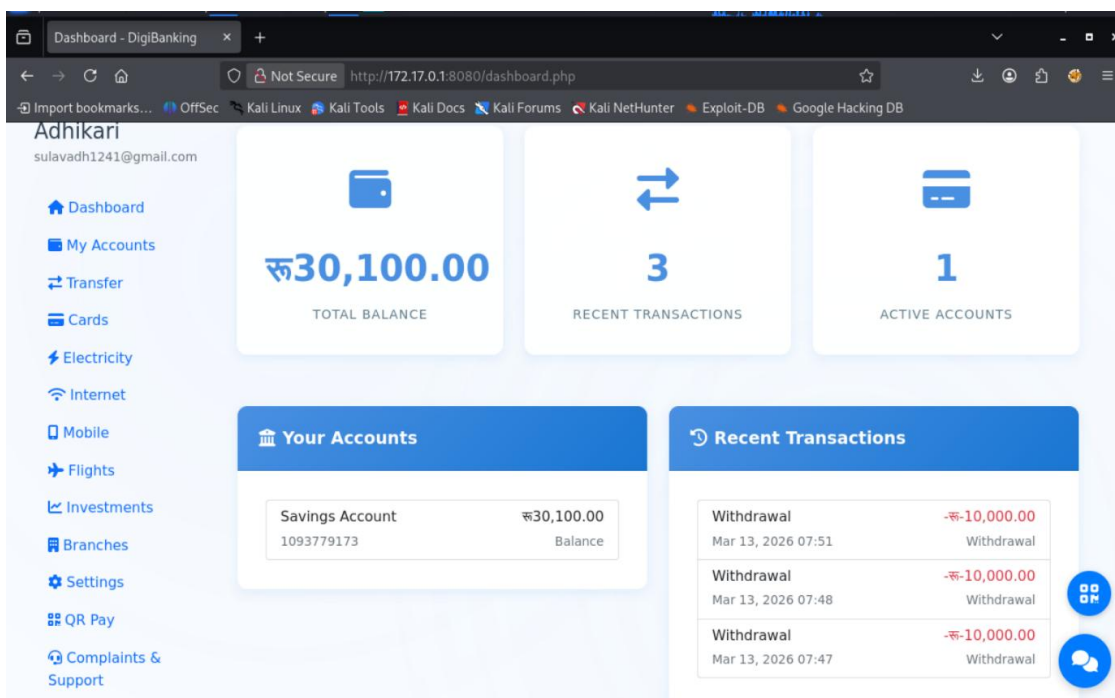


Figure 7.2.5: Dashboard - Total Balance Rs.30,100.00; 3 recent transactions at 07:47, 07:48, 07:51

### Impact:

Via Vector 1, negative amounts credit the account instead of debiting it, generating unlimited synthetic funds. Via Vector 2, an attacker can execute multiple Rs.10,000 withdrawals in rapid succession, far exceeding the stated limit. During testing, three consecutive withdrawals were each accepted on March 13, 2026 (at 07:47, 07:48, 07:51), totalling Rs.30,000 - three times the stated Rs.10,000/day limit.



### 7.3 Negative Money Transfer Manipulation [HIGH]

|                   |                                                           |
|-------------------|-----------------------------------------------------------|
| Severity          | High                                                      |
| Category          | Business Logic Vulnerability / Improper Input Validation  |
| Affected Endpoint | POST /transfer.php                                        |
| CVSS v3 Estimate  | 8.1 - High (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H) |

#### Description:

The money transfer function does not validate on the server side that the submitted transaction amount is positive. When a negative integer is submitted, the application reverses the transaction direction - instead of deducting funds from the sender Savings account, it credits the sender account with the absolute value of the negative amount. The Transfer Guidelines panel states a maximum of Rs.10,000 per day; this constraint is enforced only in the browser UI and is trivially bypassed by intercepting the HTTP request. Furthermore, the Fixed Deposit account has no server-side balance verification, allowing it to be driven into a deeply negative balance.

#### Proof-of-Concept HTTP Request:

POST /transfer.php HTTP/1.1 Host: 172.17.0.1:8080 Content-Type: application/x-www-form-urlencoded Cookie: PHPSESSID=89ae0f2d6f5c2b26efd5c9294e2d17e4 from\_account=1093779173&to\_account=7846270141&amount=-32000&transaction\_pin=3050&transfer= >>> Response: "Transfer successful!" >>> Savings account 1093779173 credited +Rs.32,000 instead of debited

#### Evidence Screenshots:

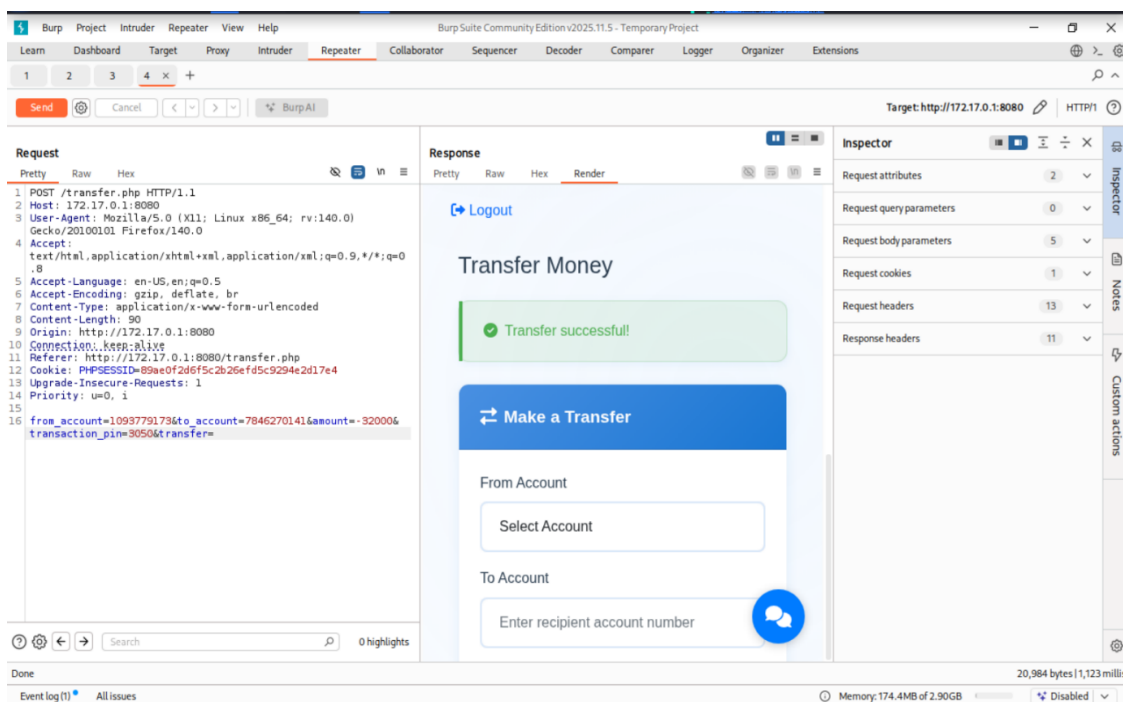


Figure 7.3.1: Burp Repeater tab 4 - from=1093779173, to=7846270141, amount=-32000; response: "Transfer successful!"

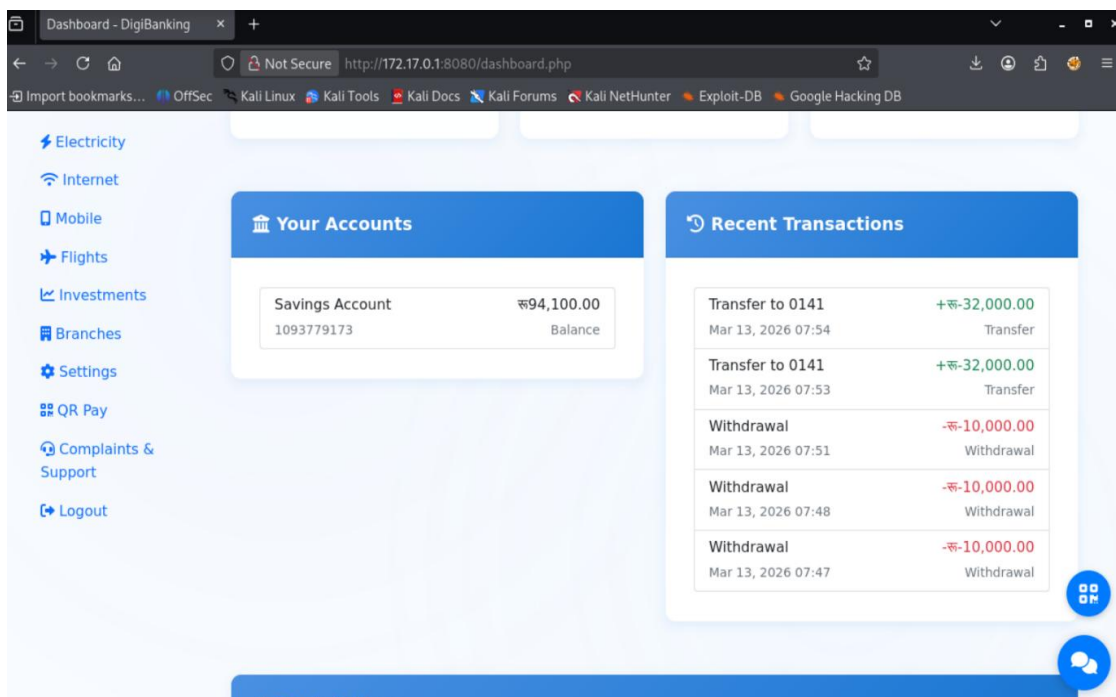


Figure 7.3.2: Dashboard - Savings 1093779173 Rs.94,100.00; two "Transfer to 0141" +Rs.-32,000 at 07:53 and 07:54

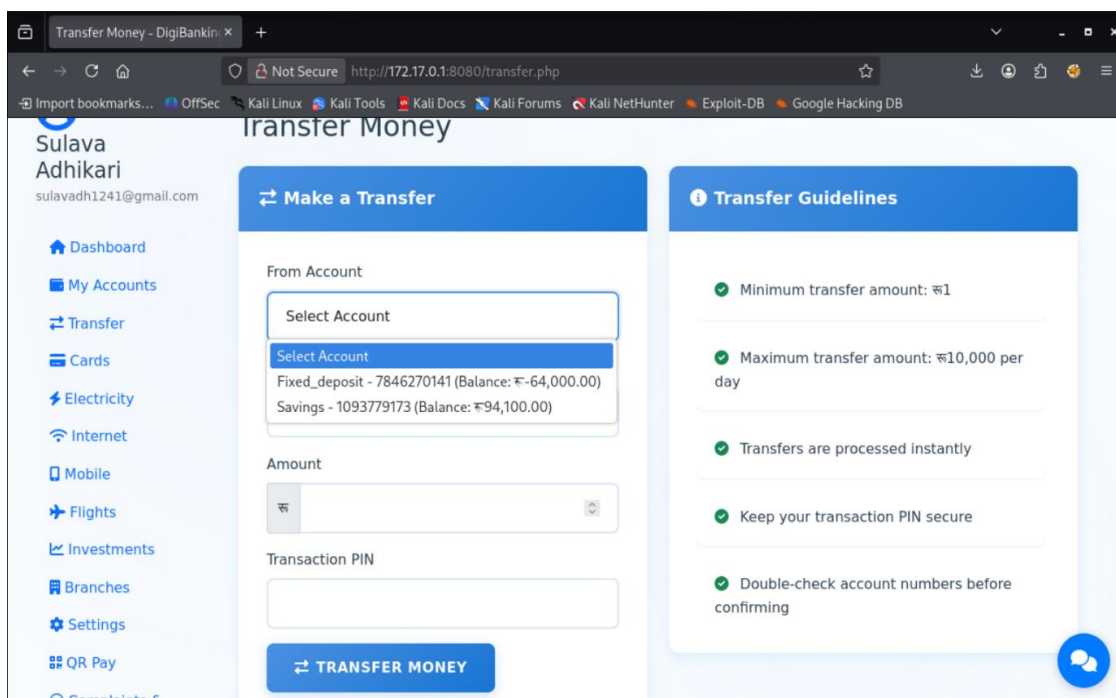


Figure 7.3.3: Transfer dropdown - Fixed\_deposit 7846270141 Balance Rs.-64,000.00; Savings 1093779173 Rs.94,100.00

### Impact:

An attacker can generate unlimited synthetic funds in their Savings account with a trivial single-line modification to any transfer request. During testing, two transfers of -Rs.32,000 each inflated the balance from Rs.30,100 to Rs.94,100. The Fixed Deposit account 7846270141 was driven to Rs.-64,000.00. Financial records are permanently corrupted and the institution faces severe regulatory and reputational risk.



## 7.4 Negative Electricity Bill Payment [MEDIUM]

|                          |                                                             |
|--------------------------|-------------------------------------------------------------|
| <b>Severity</b>          | Medium                                                      |
| <b>Category</b>          | Business Logic Vulnerability / Improper Input Validation    |
| <b>Affected Endpoint</b> | POST /electricity.php                                       |
| <b>CVSS v3 Estimate</b>  | 6.5 - Medium (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N) |

### Description:

The electricity bill payment function shares the same root vulnerability as the money transfer and withdrawal functions. The server does not validate that the submitted payment amount is positive. Submitting a negative amount to /electricity.php causes the system to credit the user account rather than debit it. The server returns "Electricity payment successful!" confirming the transaction was accepted. During testing, two submissions of amount=-15000 each credited Rs.15,000 to the account.

### Proof-of-Concept HTTP Request:

POST /electricity.php HTTP/1.1 Host: 172.17.0.1:8080 Content-Type: application/x-www-form-urlencoded Cookie: PHPSESSID=89ae0f2d6f5c2b26efd5c9294e2d17e4 account\_id=100077cd-d5f8-476a-a2b5-35ca297af2c6&customer\_number=158653228 &amount=-15000&transaction\_pin=3050&pay\_electricity= >>> Response: "Electricity payment successful!" >>> Account credited +Rs.15,000 instead of charged

### Evidence Screenshots:

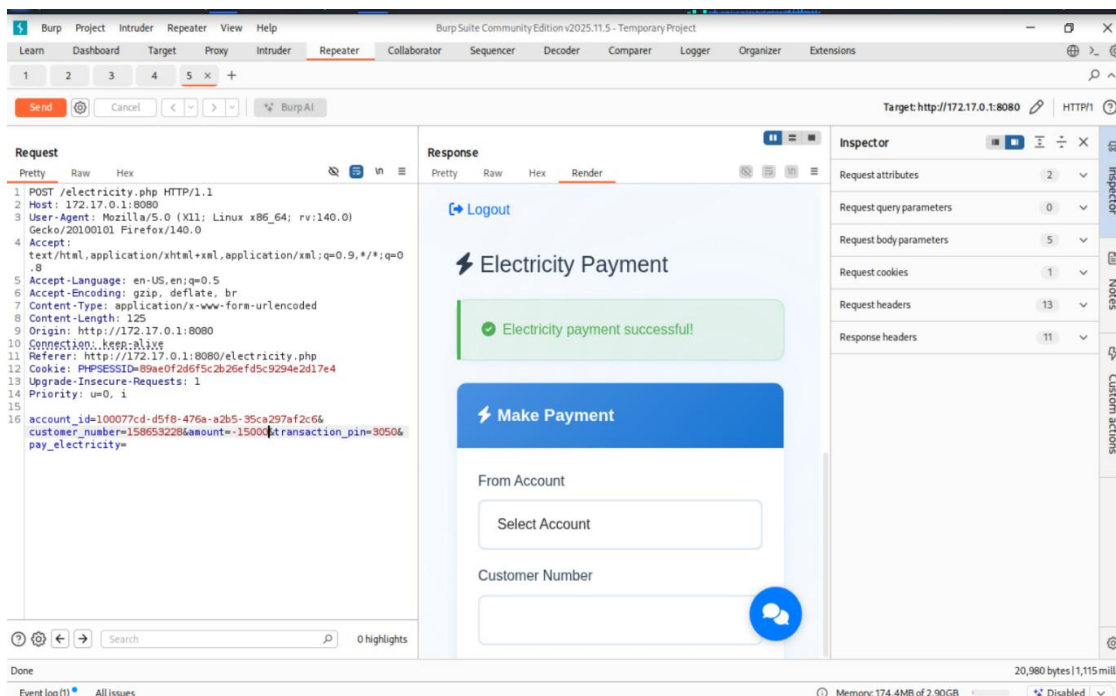


Figure 7.4.1: Burp Repeater tab 5 - amount=-15000, customer\_number=158653228; response: "Electricity payment successful!"

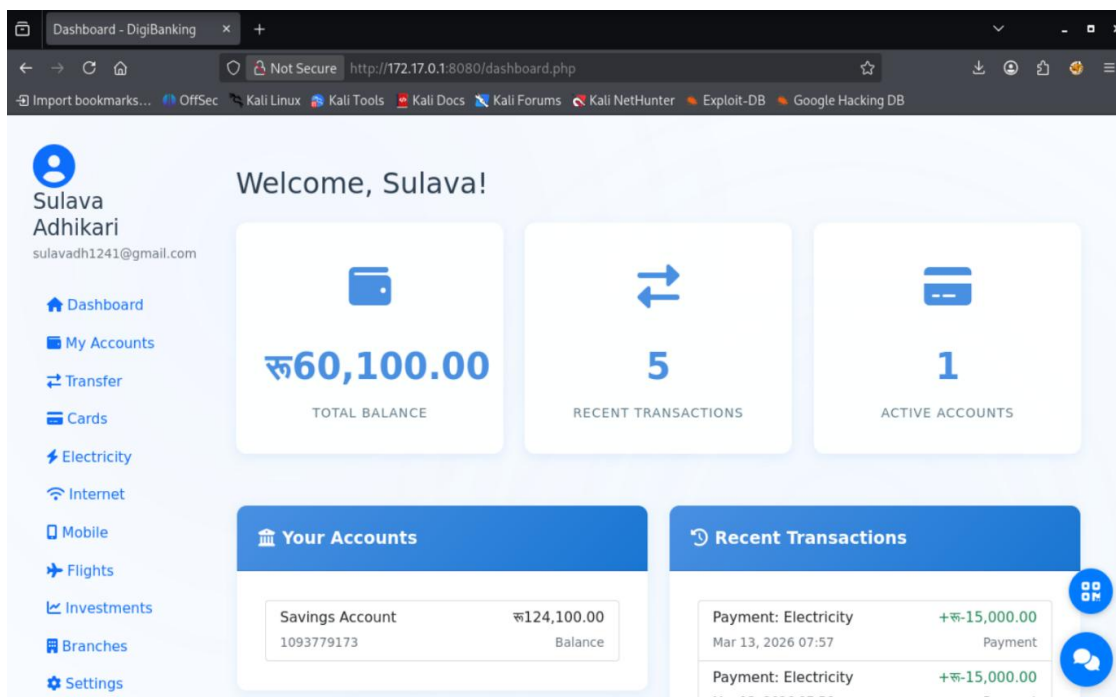


Figure 7.4.2: Dashboard - Total Rs.60,100.00; Savings Rs.124,100.00; Payment: Electricity +Rs.-15,000 at 07:56 and 07:57

### Impact:

Two electricity payment submissions each credited Rs.15,000 to the account, as confirmed by the final dashboard showing "Payment: Electricity +Rs.-15,000" entries at 07:56 and 07:57 on March 13, 2026. This vulnerability is identical in mechanism to the negative withdrawal and transfer vulnerabilities and demonstrates a systemic failure of server-side input validation across every financial transaction endpoint.

## 8. Vulnerability Summary

The table below provides a consolidated overview of all four vulnerabilities, ordered by severity. All findings were confirmed through successful exploitation and are supported by screenshot evidence.

| ID   | Vulnerability                      | Category                          | CVSS | Severity | Status    |
|------|------------------------------------|-----------------------------------|------|----------|-----------|
| V-01 | OTP Authentication Bypass          | Broken Authentication             | 9.8  | Critical | Confirmed |
| V-02 | Negative Withdrawal - Limit Bypass | Business Logic / Input Validation | 8.1  | High     | Confirmed |
| V-03 | Negative Money Transfer            | Business Logic / Input Validation | 8.1  | High     | Confirmed |
| V-04 | Negative Electricity Payment       | Business Logic / Input Validation | 6.5  | Medium   | Confirmed |

### Risk Distribution Analysis:

- 1 Critical finding - The OTP authentication bypass eliminates the entire two-factor authentication layer with a single HTTP parameter removal. Exploitable in under 60 seconds.
- 2 High findings - Negative value manipulation across withdrawal and money transfer endpoints. Both share the same root cause (absent server-side sign validation) and allow unlimited synthetic fund generation.
- 1 Medium finding - Negative electricity bill payments exploit the same absent sign validation. Slightly lower impact due to payment context.

## 9. Proof of Compromise

The following outcomes were directly observed, captured, and documented during the assessment on March 13, 2026.

| # | Finding             | Observed Outcome                                                                                                                                                                              | Figures             |
|---|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| 1 | OTP Bypass          | HTTP 302 redirect to dashboard.php issued after removing verify_otp=1 with invalid OTP 120363. Full authenticated session as Sulava Adhikari obtained. Initial balance Rs.100.00.             | Fig. 7.1.5 to 7.1.7 |
| 2 | Negative Withdrawal | Three withdrawals of -Rs.10,000 submitted (amount=-10000). Server returned "Withdrawal request successful!" each time. Balance inflated from Rs.100.00 to Rs.30,100.00 (07:47, 07:48, 07:51). | Fig. 7.2.1 to 7.2.5 |
| 3 | Negative Transfer   | Two transfers with from=1093779173, to=7846270141, amount=-32000. Server returned "Transfer successful!" each time. Savings reached Rs.94,100.00. Fixed Deposit driven to Rs.-64,000.00.      | Fig. 7.3.1 to 7.3.3 |
| 4 | Electricity Payment | Two submissions with amount=-15000 to /electricity.php. Server returned "Electricity payment successful!" each time. Final Savings balance Rs.124,100.00; Total Rs.60,100.00.                 | Fig. 7.4.1 to 7.4.2 |

## 10. Impact Assessment

---

Successful exploitation of the identified vulnerabilities would allow a malicious actor to achieve the following outcomes against any deployed instance of the DigiBank application:

### **Financial Integrity Destroyed**

All three business logic vulnerabilities (V-02, V-03, V-04) allow unlimited synthetic fund generation with zero initial capital. Account balances can be inflated to arbitrary values, corrupting the institution entire financial ledger. During testing, the Savings account balance was inflated from Rs.100.00 to Rs.124,100.00.

### **Two-Factor Authentication Rendered Ineffective**

The OTP bypass (V-01) negates the security benefit of 2FA entirely. Any attacker with valid credentials can immediately access any user account without completing the OTP step.

### **Fraud Controls Completely Bypassed**

Daily transaction limits (Rs.10,000/day) are the primary fraud detection mechanism. All four findings bypass these controls: three separate Rs.10,000 withdrawals were each accepted on the same day, exceeding the stated daily limit. Negative amounts bypass sign checks entirely.

### **Cleartext Credential and Session Interception**

All traffic - including login credentials, session tokens, OTP values, transaction PINs, and complete financial data - is transmitted over unencrypted HTTP. Any adversary with a network position can passively intercept all sensitive data.

### **Regulatory and Legal Liability**

Permitting account balances to go negative, allowing unlimited self-crediting transactions, and failing to enforce daily limits likely violates applicable financial regulatory requirements. The Fixed Deposit account 7846270141 was driven to Rs.-64,000.00 with no server-side balance check.

## 11. Remediation Recommendations

The following remediation actions are ordered by priority. Items marked Critical must be treated as emergency fixes and deployed before the application is returned to any environment.

| Ref  | Recommendation                                                                                                                                                                                                                                                              | Priority | Timeline   |
|------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|------------|
| R-01 | Fix OTP verification logic - enforce OTP completion exclusively through server-side session state (\$_SESSION["otp_verified"]). Remove the verify_otp parameter from client-side control entirely. All protected endpoints must check session state before serving content. | Critical | Immediate  |
| R-02 | Enforce server-side positive-value validation on all financial amount fields - /withdraw.php, /transfer.php, /electricity.php. Reject any amount that is zero, negative, non-numeric, or exceeds the permitted maximum.                                                     | High     | Immediate  |
| R-03 | Implement server-side cumulative daily transaction totals - store and query aggregate daily amounts per user per day. Reject any transaction that would cause the daily total to exceed the permitted threshold.                                                            | High     | Short Term |
| R-04 | Enforce HTTPS/TLS across all traffic - obtain and install a valid TLS certificate; redirect all HTTP to HTTPS; implement HSTS with minimum max-age of 31,536,000 seconds.                                                                                                   | High     | Short Term |
| R-05 | Implement OTP security hardening - enforce 5-minute OTP expiry, single-use enforcement, rate-limit after 3-5 failed attempts, bind OTP to the session that generated it.                                                                                                    | High     | Short Term |
| R-06 | Restrict directory access and suppress version disclosure - disable directory listing; block direct web access to /config/ and /includes/; set ServerTokens Prod and ServerSignature Off.                                                                                   | Medium   | Short Term |

### R-01 Implementation Example (PHP):

```
session_start(); $stored_otp = $_SESSION["generated_otp"]; $submitted = $_POST["otp"] ?? ""; if ($stored_otp !== $submitted || empty($stored_otp)) { echo json_encode(["error" => "Invalid OTP. Please try again."]); exit; } $_SESSION["otp_verified"] = true; unset($_SESSION["generated_otp"]); // Invalidate OTP after use header("Location: dashboard.php");
```

### R-02 Implementation Example (PHP):

```
$raw = $_POST["amount"] ?? ""; $amount = floatval($raw); if (!is_numeric($raw) || $amount <= 0 || $amount > MAX_TRANSACTION_LIMIT) { echo json_encode(["error" => "Invalid amount. Must be a positive value within limits."]); exit; }
```

## 12. Conclusion

This penetration test was conducted against the DigiBank web application (172.17.0.1:8080) as part of the Penetration Testing Training Programme facilitated by Danphelink Pvt. Ltd. The assessment was performed on March 13, 2026 by Sulav Adhikari, covering black-box web application testing with a primary focus on authentication mechanisms, business logic integrity, and server-side input validation.

The DigiBank application was found to be in a critically vulnerable state across multiple independent attack surfaces. Four distinct security vulnerabilities were identified and successfully exploited during a single assessment session.

| Assessment Area              | Result                                                                          |
|------------------------------|---------------------------------------------------------------------------------|
| Total Vulnerabilities Found  | 4 Vulnerabilities: 1 Critical, 2 High, 1 Medium                                 |
| Authentication Security      | <b>FAILED - 2FA completely bypassable by removing a single POST parameter</b>   |
| Financial Logic Integrity    | <b>FAILED - All transaction endpoints accept negative values</b>                |
| Transport Security           | <b>FAILED - Application runs over plain HTTP; all data in cleartext</b>         |
| Server-Side Input Validation | <b>FAILED - No amount validation across any financial endpoint</b>              |
| Daily Limit Enforcement      | <b>FAILED - Per-transaction check only; cumulative daily totals not tracked</b> |

### Priority Remediation Summary:

- IMMEDIATE - Fix OTP verification to use server-side session state only; add server-side positive-value validation to all transaction endpoints.
- SHORT TERM (within 2 weeks) - Implement HTTPS/TLS with HSTS; replace per-transaction limit checks with cumulative daily totals; restrict directory access; suppress all version headers; implement OTP expiry and rate limiting.
- ONGOING - Conduct penetration testing after every major release; integrate automated security testing into CI/CD pipeline; conduct developer training on secure coding for financial applications.

## End of Report

DigiBank Web Application Penetration Test - Sulav Adhikari - Danphelink Pvt. Ltd. - March 2026